

ЗАТВЕРДЖЕНО
Наказом ТОВ "Криптографічні Телесистеми"
від ____ 2026 р. № ____
(в редакції наказу ТОВ "Криптографічні Телесистеми"
від ____ 2026 р. № ____)

Телекомунікаційна система ERP/1
«Повний набір сервісів»

ЦІЛЬОВИЙ ПРОФІЛЬ БЕЗПЕКИ

UA.47850061.C3I.ДП-16

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
1. УПРАВЛІННЯ ДОСТУПОМ (АС)				
1	Управління обліковими записами	а. Визначити та задокументувати типи облікових записів системи, дозволених для використання в ІС для підтримки цілей, завдань, функцій і процесів організації. б. Призначити менеджерів облікових записів для управління системними обліковими записами. с. Створити умови для групового та рольового членства. д. Визначити авторизованих користувачів інформаційної системи, членство в групі та ролі, а також дозволи доступу (наприклад, привілеї) та інші атрибути (за потреби) для кожного облікового запису. е. Вимагати схвалення [Призначення: визначеною організацією відповідальною особою або роллю] запитів на створення облікових записів системи. ф. Створювати, активувати, змінювати, деактивувати та видаляти системні облікові записи відповідно до [Призначення: визначених організацією політики, процедур та умов]. г. Впровадити моніторинг використання облікових записів системи. х. Повідомляти адміністраторів облікових записів у межах [Призначення: визначеного організацією часового періоду для кожної ситуації]: 1. коли облікові записи більше не потрібні; 2. коли користувачі звільнені чи переведені; 3. коли використовуються індивідуальні системи або наявні зміни, які потребують нових знань. і. Авторизувати доступ до системи на основі: 1. Дійсної авторизації доступу. 2. Передбачуваного використання системи. 3. Інших атрибутів, що вимагаються організацією. ж. Проводити перегляд облікових записів на відповідність вимогам управління обліковими записами з [Призначення: визначеною організацією частотою]. к. Впровадити процес повторного випуску облікових даних спільного/групового облікового запису (якщо він буде розгорнутий), коли особи виходять з групи. л. Узгодити процеси управління обліковими записами з процесами звільнення та перевodu (передачі повноважень) персоналу.	АС-2	Система забезпечує створення, активацію, зміну та видалення облікових записів відповідно до політик організації. Права доступу жорстко прив'язані до ідентифікатора працівника ('subject_employee') або ролі. Параметр: account_management Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
2	Примусове застосування доступу (Access Enforcement)	Застосовувати затверджені повноваження для логічного доступу до інформації та ресурсів системи відповідно до чинної політики (правил) управління доступом.	АС-3	Усі запити до ресурсів системи примусово проходять через Policy Decision Point (PDP) модуля 'abac'. Прямий доступ до даних в обхід механізмів авторизації заборонено архітектурно. Параметр: access_enforcement Тип: boolean Значення: true
3	Принцип найменших привілеїв (Least Privilege)	Впровадити принцип мінімізації повноважень, який дозволяє користувачам (або процесам, що діють від імені користувачів) здійснювати лише такі авторизовані звернення, які необхідні для виконання визначених завдань відповідно до цілей (призначення, місії) організації та функцій.	АС-6	Профілі безпеки і ролі конфігуруються таким чином, що користувачам надаються лише ті привілеї, які необхідні для виконання їхніх посадових обов'язків. Механізм дозволів 'abac' працює за принципом 'Default-Deny'. Параметр: least_privilege Тип: boolean Значення: true
4	Блокування сеансу	а. Заборонити подальший доступ до системи шляхом ініціювання блокування пристрою після [Призначення: визначеного організацією періоду] бездіяльності або після отримання запиту від користувача. б. Зберігати блокування пристрою, поки користувач не відновить доступ, використовуючи встановлені процедури ідентифікації та автентифікації.	АС-11	Сеанс користувача автоматично блокується системою ('sync/n2o' session expiry) після визначеного періоду бездіяльності, вимагаючи повторної автентифікації. Параметр: session_lock_timeout Тип: integer Значення: 900
5	Завершення сеансу	Сеанс користувача має завершуватися автоматично після [Призначення: визначених організацією умов або тригерних подій, що вимагають припинення сеансу].	АС-12	Користувач може ініціювати завершення сеансу (logout). Крім того, система примусово завершує сеанси при досягненні максимального часу життя токена або зміни контексту безпеки. Параметр: session_termination Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
6	Дозволені дії без ідентифікації чи автентифікації	а. Визначити [Призначення: дозволені організацією дії користувачів], які можуть виконуватися в системі без ідентифікації або автентифікації відповідно до завдань та функцій організації. б. Документувати та визначити відповідне обґрунтування в плані безпеки системи дій користувача, які не потребують ідентифікації або автентифікації.	АС-14	Система явно визначає перелік відкритих сторінок та API-ендпойнтів (наприклад, портал входу або публічний довідник), доступних без автентифікації. Будь-які інші дії суворо заборонені. Параметр: permitted_unauthenticated_actions Тип: boolean Значення: true
7	Віддалений доступ	а. Встановити та задокументувати обмеження на використання, вимоги до конфігурації/підключення та рекомендації щодо здійснення кожного типу віддаленого доступу. б. Авторизувати віддалений доступ до системи, перш ніж будуть дозволені такі підключення.	АС-17	Віддалений доступ до системи керується додатковими політиками (наприклад, перевірка IP-адреси, VPN, mTLS), які інтегруються з 'sync/ca' та 'abac' для забезпечення безпеки доступу за межами захищеного периметра. Параметр: remote_access_control Тип: boolean Значення: true
8	АТРИБУТИ БЕЗПЕКИ ТА ПРИВАТНОСТІ	а. Визначити засоби для асоціювання (пов'язання) [Призначення: визначених організацією типів атрибутів безпеки та приватності], що приймають [Призначення: визначені організацією значення атрибутів безпеки та приватності] з інформацією, яка зберігається, обробляється та/або передається. б. Пов'язані атрибути безпеки та приватності мають створюватися і зберігатися разом з інформацією. с. Встановити дозволені [Призначення: визначені організацією атрибути безпеки] для [Призначення: систем, визначених організацією]. д. Визначити дозволені [Призначення: визначені організацією значення або діапазони] для кожного з встановлених атрибутів безпеки та приватності.	АС-16	Інформаційна система повинна підтримувати та динамічно пов'язувати визначені атрибути безпеки (мітки конфіденційності, ролі, посади, структурні підрозділи) з суб'єктами та об'єктами інформаційної взаємодії. Бібліотека АВАС реалізує стандарти ISO/IEC 29146:2016 та NIST SP 800-162, гарантуючи політику Zero Trust.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
9	Динамічне пов'язання атрибутів (заборона кешування)		АС-16(1)	АВАС через компонент РІР (Policy Information Point) динамічно завантажує актуальні атрибути з контексту (наприклад, стан об'єкта 'object_process' чи профіль 'subject_employee' з KVS) безпосередньо в момент виконання запиту ('request'). Це гарантує, що рішення приймається на базі поточного, а не закешованого стану безпеки. Параметр: dynamic_binding Тип: boolean Значення: true
10	Зміна значень атрибутів авторизованими особами через РАР		АС-16(2)	Точка адміністрування РАР дозволяє уповноваженим адміністраторам (які пройшли перевірку RDP) змінювати правила ('rule'), політики ('policy') та кадрові атрибути співробітників, гарантуючи, що лише особи з належними повноваженнями можуть керувати системою доступу. Параметр: authorized_changes Тип: boolean Значення: true
11	Підтримка системою пов'язання атрибутів (KVS)		АС-16(3)	Інфраструктура бази даних 'sync/kvs' нативно інтегрована з моделями 'abac.hrl'. Система зберігає зв'язки між суб'єктами та атрибутами на рівні записів (records), що не підлягають несанкціонованому перезапису. Параметр: attribute_binding_support Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
12	Пов'язання атрибутів авторизованими особами		АС-16(4)	Тільки уповноважені особи (з відповідними атрибутами безпеки) можуть створювати або делегувати повноваження (наприклад, призначати ролі 'assistant' або 'delegate' в моделі 'subject_employee'). Параметр: binding_by_authorized_individuals Тип: boolean Значення: true
13	Відображення атрибутів на пристроях виведення (nitro)		АС-16(5)	Завдяки інтеграції з 'synrc/nitro', рівні конфіденційності та безпекові атрибути об'єктів чітко рендеряться на інтерфейсі клієнта (веб-сторінках) у вигляді візуальних міток. Параметр: display_attributes Тип: boolean Значення: true
14	Підтримка пов'язання атрибутів організацією (org, branch)		АС-16(6)	В 'subject_employee' підтримуються специфічні атрибути для ієрархічної структури (поля 'org', 'branch'), що дозволяє обчислювати доступ на основі приналежності до організаційної одиниці. Параметр: org_binding_support Тип: boolean Значення: true
15	Послідовна інтерпретація атрибутів (ХАСМЛ algorithms)		АС-16(7)	Використання стандартизованих алгоритмів комбінування політик ХАСМЛ (алгоритми 'all' або 'any') у PDP гарантує строгу та несуперечливу математичну інтерпретацію безпекових обмежень по всій системі. Параметр: consistent_interpretation Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
16	Техніки та технології пов'язання атрибутів (Pattern Matching, CA)		АС-16(8)	Механізми Pattern Matching платформи Erlang/OTP використовуються для швидкого та безпомилкового порівняння атрибутів. Інтеграція криптографічних підписів ('sign/c') у структуру об'єкта підтверджує автентичність його міток. Параметр: binding_techniques Тип: boolean Значення: true
17	Перепризначення атрибутів згідно з життєвим циклом		АС-16(9)	Політики можуть передбачати логіку перепризначення атрибутів у процесі життєвого циклу об'єкта (наприклад, після підписання документа його атрибут статусу змінюється, що автоматично змінює правила доступу до нього). Параметр: attribute_reassignment Тип: boolean Значення: true
18	Конфігурація атрибутів уповноваженими особами (PAR API)		АС-16(10)	Інфраструктура PAR надає API для гнучкого налаштування нових типів атрибутів і політик, гарантуючи, що ці налаштування виконуються тільки згідно встановлених процедур адміністрування. Параметр: authorized_configuration Тип: boolean Значення: true
19	УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ	Застосувати затверджені повноваження для управління потоком інформації всередині системи та між пов'язаними системами на основі [Призначення: визначеними організацією політиками управління інформаційним потоком].	АС-4	Інформаційна система повинна забезпечувати виконання дозволів та заборон щодо передачі (руху) інформації. Бібліотека BPE (Business Process Engine) реалізує це через моделювання інформаційних потоків у стандарті BPMN 2.0.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
20	Атрибути безпеки об'єкту		АС-4(1)	ВРЕ перед будь-яким переходом до наступного кроку ('bre:next') аналізує атрибути (метадані, документи), прив'язані до процесу. Шлюзи перевіряють ці мітки для ухвалення рішень маршрутизації. Параметр: object_security_attributes Тип: boolean Значення: true
21	Домени обробки (ізолювані процеси Erlang)		АС-4(2)	Кожен BPMN-процес виконується як окремий ізолюваний процес віртуальної машини Erlang (Actor). Ці процеси створюють незалежні безпекові домени обробки інформації без спільної пам'яті. Параметр: processing_domains Тип: boolean Значення: true
22	Управління інформаційним потоком (SequenceFlow)		АС-4(3)	Сутність 'sequenceFlow' (ребра графу BPMN) математично обмежує єдині можливі шляхи передачі інформації між задачами. Параметр: enforce_sequence_flow Тип: boolean Значення: true
23	Управління потоком зашифрованої інформації		АС-4(4)	ВРЕ здатний маршрутизувати зашифровані payload-дані як непрозорі (opaque) структури, залишаючи розшифрування авторизованим клієнтам або конкретним сервісним завданням ('serviceTask'). Параметр: encrypted_payloads Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
24	Вбудовування типів даних (Erlang Records)		АС-4(5)	Об'єкти інформаційного потоку строго типізовані через структури 'record' (наприклад, '#userTask{}', '#messageEvent{}'). Це запобігає переміщенню невідомих форматів. Параметр: embedded_data_types Тип: boolean Значення: true
25	Метадані (список docs у ВРЕ)		АС-4(6)	ВРЕ керує метаданими документів, використовуючи внутрішній список 'docs' (API 'bre:docs/1', 'bre:amend/2'), що невідривно супроводжує потік процесу. Параметр: metadata_management Тип: boolean Значення: true
26	Механізми одностороннього потоку (DAG)		АС-4(7)	Направлені ациклічні графи (DAG) BPMN природно реалізують односторонню передачу даних від 'beginEvent' до 'endEvent' без можливості повернення (якщо це не передбачено схемою). Параметр: one_way_flow Тип: boolean Значення: true
27	Політики безпеки (Gateways)		АС-4(8)	Логічні шлюзи ('gateway') виступають інтегрованими фільтрами, які застосовують політики безпеки на розгалуженнях потоку. Параметр: security_policies Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
28	Перевірки, що проводить персонал (UserTask)		АС-4(9)	Використання ‘#userTask{ }’ зупиняє автоматичний потік інформації та вимагає ручної перевірки (Human-in-the-loop) і підтвердження для продовження маршруту. Параметр: personnel_checks Тип: boolean Значення: true
29	Активація та деактивація фільтрів політики (BoundaryEvent)		АС-4(10)	Використання подій, як-от ‘boundaryEvent’ (Boundary Events), дозволяє динамічно активувати обхідні гілки політик в залежності від виникнення інцидентів або таймаутів. Параметр: filter_activation Тип: boolean Значення: true
30	Конфігурація фільтрів політики безпеки (XML)		АС-4(11)	Правила маршрутизації (фільтри) завантажуються декларативно з BPMN XML файлів та транслуються у незмінні правила Erlang (‘bpe:load/1’). Параметр: filter_configuration Тип: boolean Значення: true
31	Ідентифікатори типу даних (MessageEvent)		АС-4(12)	Система розрізняє вхідні повідомлення через обробку ‘messageEvent’ з відповідними ідентифікаторами повідомлень, ігноруючи нерозпізнані сигнали. Параметр: data_type_identifiers Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
32	Декомпозиція на субкомпоненти (Call Activity)		AC-4(13)	ВРЕ підтримує виклик підпроцесів ('Call Activity'), що дозволяє розбити складні потоки на ізольовані субкомпоненти зі своїми власними політиками. Параметр: subcomponent_decomposition Тип: boolean Значення: true
33	Обмеження фільтра політики (conditions)		AC-4(14)	Можливості маршрутизації обмежені набором умов 'condition()', які дозволяють математично гарантувати неперетин потоків. Параметр: policy_filter_constraints Тип: boolean Значення: true
34	Виявлення несанкціонованої інформації		AC-4(15)	При спробі передати процесу повідомлення, яке не відповідає поточній стадії потоку (unauthorized message), система автоматично відкидає його або фіксує в лог як невалідний event. Параметр: unauthorized_info_detection Тип: boolean Значення: true
35	Передача інформації про взаємопов'язані системи (ServiceTask)		AC-4(16)	Компонент '#serviceTask{}' дозволяє інтегрувати механізми перевірки даних, перш ніж передати інформаційний потік до інших ІТС (наприклад, через API REST або RPC). Параметр: interconnected_systems_transfer Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
36	Прив'язка атрибуту безпеки (Process ID)		АС-4(18)	Інформація в рамках потоку жорстко прив'язується до Process ID (Id інстанції). Усі документи успадковують обмеження доступу поточного процесу. Параметр: security_attribute_binding Тип: boolean Значення: true
37	Перевірка метаданих (BPMN compare)		АС-4(19)	BPMN-умови підтримують функції типу '{compare, Field, ConstCheckAgainst}', що перевіряють значення конкретних метаданих об'єкта під час прийняття рішення про маршрут. Параметр: metadata_validation Тип: boolean Значення: true
38	Затверджені рішення (Default-Deny)		АС-4(20)	Erlang Match Specifications та XACML гарантують, що лише явно затверджені алгоритми маршрутизації виконуються (Default-Deny принцип). Параметр: approved_decisions Тип: boolean Значення: true
39	Фізичне та логічне відділення інформаційних потоків		АС-4(21)	Логічне відділення гарантується механізмом процесів ОТР VM. Можливість виконання різних процесів на різних фізичних нодах Erlang-кластера забезпечує фізичне відділення потоків. Параметр: physical_logical_separation Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
40	Єдиний доступ (bre:next)		АС-4(22)	Централізований компонент контролю 'bre:next' слугує єдиною точкою (Choke Point) доступу та маршрутизації для всіх інформаційних потоків. Параметр: single_access_point Тип: boolean Значення: true
41	Модифікована інформація, яка не підлягає оприлюдненню (scrubbing)		АС-4(23)	При поверненні історії та статусів через API клієнту, BPE може відфільтровувати та очищати внутрішні атрибути ('scrubbing'), не допускаючи витоку чутливої інформації. Параметр: scrub_hidden_fields Тип: boolean Значення: true
42	Нормалізований формат (BPE Record)		АС-4(24)	Весь внутрішній потік конвертується в уніфікований стандартизований формат ('BPE Record Format'), незалежно від того, як дані надійшли на вході. Параметр: normalized_format Тип: boolean Значення: true
43	Очищення даних (Garbage Collection, End Event)		АС-4(25)	Вбудовані механізми Garbage Collection віртуальної машини Erlang та знищення об'єктів пам'яті ізольованого процесу після завершення ('End Event') забезпечують очищення даних з ОЗУ. Параметр: data_sanitization Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
44	Дії з фільтрації аудиту (hist у KVS)		АС-4(26)	Кожен крок і зміна маршруту фіксується у вигляді об'єкта 'hist' у 'kvs', створюючи прозорий ланцюг подій, де шлюзи та фільтри залишають свій слід. Параметр: audit_filter_actions Тип: boolean Значення: true
45	Незалежні фільтруючі механізми (АВАС + ВРЕ)		АС-4(27)	Дозвіл на доступ (АВАС) та перевірка логіки процесу (ВРЕ) працюють як архітектурно незалежні механізми, підсилюючи концепцію "Defense-in-depth". Параметр: independent_filtering Тип: boolean Значення: true
46	Лінійні фільтрувальні канали (Linear Pipeline)		АС-4(28)	ВРЕ підтримує лінійну маршрутизацію (Linear Pipeline), коли 'SequenceFlow' гарантовано не має відгалужень, забезпечуючи послідовне виконання політик без ризику обходу. Параметр: linear_pipelines Тип: boolean Значення: true
47	Механізми оркестровки		АС-4(29)	Ядро ВРЕ виступає єдиним централізованим механізмом оркестровки інформаційного обміну в рамках системи. Параметр: orchestration_mechanisms Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
48	Фільтрація з використанням кількох процесів (Parallel Gateway)		АС-4(30)	Компонент 'Parallel Gateway' ('#gateway{type=parallel}') створює декілька паралельних потоків, кожен з яких може мати власні незалежні правила фільтрації. Параметр: multi_process_filtering Тип: boolean Значення: true
49	Запобігання передачі вмісту		АС-4(31)	Якщо інформаційний об'єкт не відповідає політиці (фільтр на Gateway відхилив вміст), процес переривається або спрямовується на подію помилки (Error Event). Параметр: content_transfer_prevention Тип: boolean Значення: true
50	Вимоги до процесу передачі інформації (Receive/Send Task)		АС-4(32)	Механізми 'Receive Task' та 'Send Task' строго декларують вимоги до структури payload-повідомлень перед тим, як дозволити зовнішній чи внутрішній обмін. Параметр: transfer_process_requirements Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
2. ОБІЗНАНІСТЬ ТА НАВЧАННЯ (АТ)				
51	Навчання з обізнаності щодо безпеки	Впровадити базові тренінги з підвищення обізнаності у сфері безпеки та приватності для користувачів системи (включно з менеджерами, керівниками компаній і підрядниками): а. Забезпечити навчання грамотності з питань безпеки та конфіденційності для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників): 1. як частину початкового навчання для нових користувачів і [Призначення: частота, визначена організацією] після цього; 2. якщо цього потребують системні зміни або наступні [Призначення: події, визначені організацією]. б. Використовувати наведені нижче методи, щоб підвищити рівень безпеки та конфіденційності користувачів системи [Завдання: визначені організацією методи поінформованості]; с. Оновлювати навчання грамотності та зміст обізнаності [Завдання: частота, визначена організацією] і наступні [Завдання: події, визначені організацією]; д. Включити уроки, отримані з внутрішніх або зовнішніх інцидентів безпеки або порушень, у навчання грамотності та методи підвищення обізнаності.	АТ-2	Програми навчання та інструктажі (див. розділ АТ у digital-profile.pdf). Параметр: security_awareness_training_ref Тип: string Значення: digital-profile.pdf
52	Навчання з питань безпеки, залежне від ролі	а. Забезпечити проведення навчання з питань безпеки та приватності на основі ролей для працівників з ролями та обов'язками: [Призначення: визначені організацією ролі та обов'язки]: 1. перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків і [Призначення: частота, визначена організацією] після цього; 2. коли цього потребують системні зміни. б. Оновити навчальний контент на основі ролей [Призначення: частота, визначена організацією] і наступні [Призначення: події, визначені організацією]; с. Включіть у рольове навчання, інформацію, отриману з внутрішніх або зовнішніх інцидентів та порушень безпеки.	АТ-3	Спеціалізоване навчання для адміністраторів (див. розділ АТ у digital-profile.pdf). Параметр: role_based_training_ref Тип: string Значення: digital-profile.pdf
3. АУДИТ ТА ПІДЗВІТНІСТЬ (АУ)				
53	Узагальнення записів про аудит з декількох джерел (feeds)		AU-2(1)	ВРМН підтримує паралельні ланцюги (feeds, streams), що дозволяє агрегувати записи про аудит з декількох джерел у єдиний потік журналу. Параметр: audit_aggregation Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
54	Перегляд та оновлення (індексація hist)		AU-2(3)	Записи аудиту періодично індексуються, що дозволяє швидко витягувати всю історію (наприклад, через 'bpe:hist/1'). Параметр: audit_review_update Тип: boolean Значення: true
55	Зміст записів аудиту (метадані, Permit/Deny)	Переконаватися, що записи аудиту містять інформацію, яка встановлює наступне: а. який тип події стався; б. коли відбулася подія; с. де відбулася подія; д. джерело події; е. наслідки події; ф. результат події та ідентифікатор будь-яких осіб або суб'єктів, пов'язаних з подією.	AU-3	Інформація в логах ВРМН (особливо при збереженні об'єктів ВРЕ/ABAC) містить вичерпні метадані: тип події, суб'єкт, цільовий об'єкт, результат операції (Permit/Deny) та позначку часу, що повністю закриває вимоги AU-3. Параметр: audit_content_metadata Тип: boolean Значення: true
56	Місткість сховища записів аудиту (розподілені бекенди)	Розподіляти місткість сховища записів аудиту у відповідності до [Призначення: визначених організацією вимог до зберігання записів аудиту].	AU-4	ВРМН може використовувати розподілені бекенди (Riak KV, розподілена Mnesia, KAI), що дозволяє горизонтально масштабувати місткість сховища логів (AU-4) без зупинки системи. Параметр: audit_storage_capacity Тип: boolean Значення: true
57	Позначка часу (erlang:system_time)		AU-8(1)	Усі ідентифікатори та події, що генеруються в ВРМН (наприклад, через генератор 'id_seq'), прив'язані до високоточного системного часу Erlang ('erlang:system_time/1'). Це забезпечує надійну прив'язку подій до точного часу (AU-8(1)). Параметр: sync_time_source Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
58	Апаратні носії одноразового запису (Append-Only)		AU-9(1)	Архітектура Append-Only гарантує, що записи не оновлюються (по UPDATE). Це створює ефект апаратного "Write-Once-Read-Many" (AU-9(1)). Видалити запис без порушення криптографічної чи логічної цілісності ланцюга посилань практично неможливо. Параметр: append_only_enforced Тип: boolean Значення: true
59	Неспростовність (Ланцюжок збереження доказів)		AU-10(3)	Журнали BPMN слугують доказовою базою (Ланцюжок збереження доказів AU-10(3)). У комбінації з 'sync/ca' записи можуть підписуватися ЕЦП (AU-10(5)), що гарантує 100% неспростовність дій автора транзакції. Параметр: non_repudiation Тип: boolean Значення: true
60	Довгострокова можливість отримання записів аудиту		AU-11(1)	Сховища типу RocksDB (в якості бекенда BPMN) оптимізовані для довгострокового зберігання петабайтів даних (Long-Term Storage) із забезпеченням швидкого доступу до історичних записів (AU-11(1)). Параметр: log_retention_days Тип: integer Значення: 1825

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
61	Огляд, аналіз та звітність про аудит	а. Переглядати та аналізувати записи системного аудиту [Призначення: з визначеною організацією частотою] для виявлення [Призначення: визначеної організацією неналежної або незвичайної діяльності]. б. Відправляти звіт про аудит [Призначення: визначеним організацією персоналу або посадам]. с. Налаштувати рівні огляду аудиту, аналізу та звітності в рамках системи, коли змінюється рівень ризику на основі інформації від правоохоронних органів, розвідувальної інформації або від інших достовірних джерел інформації.	AU-6	Аналіз аудиту відбувається за допомогою консольних інструментів платформи (наприклад, 'kvs:hist/1' або інтерфейсів Erlang Shell). Також доступний експорт журналів для SIEM. Параметр: audit_analysis_tools Тип: boolean Значення: true
62	Генерація аудиту	а. Забезпечити генерацію даних аудиту для типів подій, що перевіряються в AU-2а в [Призначення: визначених організацією компонентах системи]. б. Дозволити [Призначення: визначеному організацією персоналу або посадам] вибирати, які типи подій, що перевіряються, повинні перевірятися окремими компонентами системи; с. Генерувати записи аудиту для типів подій, визначених в AU-2с. з вмістом згідно з AU-3.	AU-12	KVS забезпечує генерацію записів аудиту для всіх операцій створення, оновлення (через створення нової ревізії) та видалення, гарантуючи фіксацію критичних подій безпеки. Параметр: audit_generation Тип: boolean Значення: true
4. УПРАВЛІННЯ КОНФІГУРАЦІЄЮ (СМ)				
63	Базова конфігурація (Baseline Configuration)	а. Розробити, задокументувати та підтримувати за допомогою заходів конфігурації поточні базові налаштування системи. б. Переглядати та оновлювати базові налаштування системи: 1. з [Призначення: визначеною організацією частотою]; 2. за потреби внаслідок [Призначення: визначених організацією обставин]; 3. коли встановлені нові або оновлені компоненти системи.	СМ-2	Файл 'erpuno.ex' фіксує єдину базову конфігурацію (Baseline) безпеки для всієї системи. Зміни в конфігурації застосовуються виключно через оновлення коду, що забезпечує строгий контроль та аудит змін. Параметр: baseline_configuration_code Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
64	Контроль змін конфігурації	a. Визначити типи змін у системі, які контролюються конфігурацією. b. Переглядати запропоновані зміни в конфігурації, контрольовані системою, і схвалити або відхилити ці зміни з явним урахуванням аналізу наслідків безпеки. c. Документувати рішення зі зміни конфігурації системи. d. Впровадити схвалені зміни конфігурації в систему. e. Зберігати записи змін конфігурації системі впродовж [Призначення: певного періоду часу, визначеного організацією]. f. Здійснювати моніторинг і аналіз дій, пов'язаних зі змінами конфігурації системи. g. Координувати та впроваджувати нагляд за діяльністю з управління змінами конфігурації за допомогою [Призначення: елементу управління змінами конфігурації, визначеного організацією], який викликається [Вибір (один або кілька): [Призначення: з визначеною організацією частотою]; [Призначення: визначені організацією умови зміни конфігурації]].	СМ-3	Оскільки CMDDB є частиною вихідного коду (Elixir модуль), всі зміни проходять через стандартний процес розробки (Code Review, CI/CD, контроль версій Git), унеможливаючи несанкціоноване втручання в налаштування на "живій" системі. Параметр: configuration_change_control Тип: boolean Значення: true
65	Налаштування конфігурації	a. Встановити та задокументувати параметри конфігурації компонентів, які застосовуються в системі, які відображають найбільш обмежений режим, що відповідає експлуатаційним вимогам, використовуючи [Призначення: визначені організацією загальні безпечні конфігурації]. b. Реалізувати конфігураційні установки. c. Визначити, задокументувати та затвердити будь-які відхилення від встановлених конфігураційних параметрів конфігурації для [Призначення: визначених організацією компонентів системи] на основі [Призначення: визначених організацією експлуатаційних вимог]. d. Відстежувати та керувати змінами конфігураційних параметрів відповідно до організаційної політики та процедур.	СМ-6	Параметри політик безпеки та їхні значення за замовчуванням жорстко зашиті в 'eruno.ex'. Компілятор генерує незмінний об'єктний файл, який гарантує виконання затверджених налаштувань під час роботи. Параметр: compile_time_config Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
66	Інвентаризація компонентів ІТС	а. б. Розробити та задокументувати процес інвентаризації компонентів системи, який: 1. точно описує поточну систему; 2. охоплює всі компоненти в межах акредитації системи; 3. не включає повторний облік компонентів або компонентів, будь-якої іншої системи; 4. визначає рівень деталізації, який є необхідним для відстеження та звітування; 5. включає інформацію для досягнення підзвітності компонентів системи: [Призначення: визначена організацією інформація, необхідна для досягнення ефективної підзвітності компонентів системи]. Переглядати та оновлювати опис компонентів системи з [Призначення: визначеною організацією частотою].	СМ-8	Профіль автоматично фіксує перелік використовуваних компонентів системи (бібліотеки 'sync/kvs', 'sync/ca' тощо) та їхні параметри, забезпечуючи інтегральну інвентаризацію модулів захисту. Параметр: component_inventory Тип: boolean Значення: true
67	План управління конфігурацією	Унікально ідентифікувати та автентифікувати користувачів або процеси, що діють від імені користувачів.	СМ-9	Профіль 'ERPUNO.Profile' слугує самодокументованим планом управління конфігураціями, здатним автоматично генерувати актуальну документацію (через метод 'generate_md/0'). Параметр: auto_generate_documentation Тип: boolean Значення: true
5. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (ІА)				
68	Ідентифікація та автентифікація (організаційні користувачі)		ІА-2	Система однозначно ідентифікує та автентифікує (перевіряє справжність) організаційних користувачів та процеси, що діють від їх імені, перед тим, як дозволити їм доступ до захищених ресурсів. Параметр: org_user_auth Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
69	Ідентифікація та автентифікація (неорганізаційні користувачі)		IA-8	Зовнішні користувачі, що підключаються з публічних мереж, проходять сувору автентифікацію (наприклад, за допомогою mTLS або інтеграції з КЕП) для запобігання анонімному або підробленому доступу. Параметр: non_org_user_auth Тип: boolean Значення: true
70	Автентифікація на основі пароля (хешування)		IA-5(1)	Для паролів чи PING-кодів (наприклад, для розблокування контейнерів PKCS#12) використовуються криптостійкі функції хешування з сіллю для запобігання атакам. Параметр: password_based_auth Тип: boolean Значення: true
71	Автентифікація на основі відкритого ключа		IA-5(2)	Є основним профілем бібліотеки 'ca'. Вона генерує, перевіряє (validate) та керує життєвим циклом інфраструктури відкритих ключів (X.509), забезпечуючи строгу автентифікацію. Параметр: pki_enabled Тип: boolean Значення: true
72	Зміна автентифікаторів до доставки (CSR)		IA-5(5)	Система підтримує протоколи, за яких приватний ключ генерується на пристрої клієнта, а до СА відправляється лише Certificate Signing Request (CSR). Це гарантує зміну/встановлення ключів ще до факту доставки готового сертифіката користувачу. Параметр: pre_delivery_change Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
73	Захист автентифікаторів (РЕМ/PKCS#12)		IA-5(6)	Приватні ключі (автентифікатори) зберігаються в захищеному зашифрованому вигляді (наприклад, контейнери формату РЕМ з паролем або PKCS#12), що унеможливорює використання ключів без знання пароля доступу. Параметр: authenticator_protection Тип: boolean Значення: true
74	Відсутність вбудованих незашифрованих статичних автентифікаторів		IA-5(7)	Бібліотека заохочує динамічну генерацію ключів під час ініціалізації середовища (Root CA), що виключає необхідність зберігання "hardcoded" секретів у вихідному коді системи. Параметр: no_unencrypted_static Тип: boolean Значення: true
75	Багатосистемні облікові записи (mTLS/SSO)		IA-5(8)	Сертифікати X.509, видані 'synrc/ca', можуть використовуватись як багатосистемний засіб автентифікації (на кшталт mTLS/SSO) для доступу до різноманітних мікросервісів та ERP-компонентів, розгорнутих у спільному домені довіри. Параметр: multi_system_accounts Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
76	Управління об'єднанням автентифікаторів (Intermediate CA)		IA-5(9)	Підтримується архітектура федерації ключів (Federation) за рахунок використання ланцюгів сертифікатів (Intermediate CAs) та можливості перевіряти крос-сертифікаційні підписи (Cross-Certification). Параметр: federation_management Тип: boolean Значення: true
77	Динамічне зв'язування мандатів		IA-5(10)	Бібліотека дозволяє видавати короткострокові сертифікати, що динамічно зв'язуються з конкретною сесією, IP-адресою чи атрибутами користувача (Dynamic Credential Binding). Параметр: dynamic_credential_binding Тип: boolean Значення: true
78	Автентифікація на основі апаратних токенів		IA-5(11)	'synrc/ca' прозора підтримує роботу з підписами, згенерованими на апаратних захищених носіях (Hardware Tokens, HKI, e-Токени, PKCS#11). Серверній частині потрібен лише відкритий ключ для валідації. Параметр: hardware_token_auth Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
79	Ефективність біометричної автентифікації (Secure Enclave)		IA-5(12)	Хоча 'ca' працює з криптографією, будь-яка біометрична автентифікація (наприклад, TouchID, FaceID) на клієнті конвертується в криптографічний підпис (наприклад, через Secure Enclave), який успішно валідується модулями 'sync/ca'. Параметр: biometric_efficiency Тип: boolean Значення: true
80	Закінчення терміну дії автентифікаторів (NotBefore/NotAfter)		IA-5(13)	Жорстко перевіряються поля 'NotBefore' та 'NotAfter' в сертифікатах X.509. Сертифікати зі строком дії, що минув, автоматично відхиляються без можливості оскарження. Параметр: authenticator_expiration Тип: boolean Значення: true
81	Управління змістом довірчих сховищ (Trust Stores)		IA-5(14)	На рівні сервера бібліотека керує сховищем довірених кореневих сертифікатів (Trust Store, 'priv/cacerts'). Оновлення або відкликання (через CRL) довіри до Root CA автоматично реплікується на політику доступу. Параметр: trust_store_management Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
82	Продукти та послуги, затверджені уповноваженим органом (ДСТУ 4145-2002)		IA-5(15)	Завдяки абстракції криптографічних примітивів, 'synrc/ca' підтримує державні криптографічні стандарти (наприклад, алгоритм цифрового підпису ДСТУ 4145-2002), необхідні для побудови систем, затверджених Державною службою спеціального зв'язку та захисту інформації (ДССЗІ). Параметр: approved_products Тип: boolean Значення: true
83	Передача довірчої автентифікації зовнішньої сторони (АЦСК)		IA-5(16)	'synrc/ca' здатна перевіряти підписи, накладені зовнішніми Акредитованими центрами сертифікації ключів (АЦСК), забезпечуючи довірчу автентифікацію зовнішніх сторін. Параметр: external_auth_transfer Тип: boolean Значення: true
84	Менеджер паролів (KeyStores)		IA-5(18)	Незважаючи на те, що 'synrc/ca' не є менеджером паролів у звичному розумінні, механізми захисту ключів (KeyStores, PKCS#12) виступають у ролі захищених криптографічних сейфів, які можна відкрити лише спеціалізованими засобами із дотриманням секретності. Параметр: password_manager Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
6. РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR)				
85	Навчання з реагування на інциденти		IR-2	Інтерфейс ‘erguno/itsm’ надає контекстні підказки та інструкції безпосередньо у формах обробки інцидентів, що виконує функцію інтерактивного навчання та підтримки персоналу в кризових ситуаціях. Параметр: incident _ response _ training Тип: boolean Значення: true
86	Тестування реагування на інциденти		IR-3	Можливості ВРЕ-движка дозволяють запускати симуляції інцидентів у тестовому середовищі ‘itsm’ для регулярного тестування планів реагування без впливу на продуктивну систему. Параметр: incident _ testing _ simulation Тип: boolean Значення: true
87	Обробка інцидентів		IR-4	Будь-який інцидент безпеки автоматично реєструється як тикет у модулі ‘itsm’. Процес обробки (‘incident _ management _ process’) гарантує, що інцидент пройде всі необхідні етапи: виявлення, ізоляція, усунення, відновлення. Параметр: incident _ handling Тип: boolean Значення: true
88	Моніторинг інцидентів		IR-5	Статуси інцидентів у реальному часі відображаються на дашбордах ‘erguno/itsm’. ВРЕ-движок дозволяє призначати SLA-таймаути (Boundary Events) для ескалації інцидентів, якщо час реакції перевищено. Параметр: incident _ monitoring Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
89	Звітність про інциденти		IR-6	Система 'erpuno/itsm' автоматично формує звіти про інциденти, надаючи вичерпну інформацію про порушені сервіси, час простою (SLA) та дії команди, що закриває вимоги внутрішньої та зовнішньої звітності. Параметр: automated_incident_reporting Тип: boolean Значення: true
90	Допомога у реагуванні на інциденти		IR-7	Вбудовані засоби комунікації в рамках тикету (коментарі, призначення експертів, інтеграція з базою знань) забезпечують оперативну допомогу та координацію групи безпеки під час інциденту. Параметр: incident_assistance Тип: boolean Значення: true
91	План реагування на інциденти		IR-8	Сам конфігураційний код процесів 'erpuno/itsm' виступає в ролі актуального та виконуваного плану реагування на інциденти (Executable Incident Response Plan), усуваючи розбіжність між документацією та реальністю. Параметр: executable_ir_plan Тип: boolean Значення: true
92	Реагування на витік інформації (Information Spillage)		IR-9	Спеціалізовані BPMN-схеми в 'itsm' передбачені для обробки витоків інформації. Вони включають обов'язкові кроки ідентифікації скомпрометованих даних, блокування доступу ('abac') та сповіщення регулятора. Параметр: information_spillage_response Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
7. ЗАХИСТ НОСІЇВ ІНФОРМАЦІЇ (МР)				
93	Доступ до носіїв інформації (через Erlang VM)		МР-2(1)	Прямий доступ до файлів БД (RocksDB/Mnesia) на носіях закритий на рівні ОС. Весь логічний доступ здійснюється виключно через інтерфейс KVS всередині віртуальної машини Erlang, яка діє як обмежений шлях доступу (МР-2(1)). Параметр: os_level_access_control Тип: boolean Значення: true
94	Криптографічний захист носіїв (Data-at-Rest)		МР-4(1)	KVS підтримує політики постійного збереження даних на диск (Disk Persistence). Захист інформації в стані спокою (Data-at-Rest) реалізується через інтеграцію з шифруванням файлової системи (LUKS) або шифруванням значень (МР-4(1)). Параметр: encryption_at_rest Тип: boolean Значення: true
95	Транспортування носіїв інформації (TLS-реплікація)		МР-5(1)	В розподіленому кластері KVS реплікує дані (переміщує їх) між нодами. Цей процес транспортування інформації захищається за допомогою TLS (Erlang Distribution over TLS), запобігаючи перехопленню даних поза контрольованими зонами (МР-5(1), МР-5(4)). Параметр: tls_replication Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
96	Знищення інформації на носіях (Tombstones)		MP-6(8)	Хоча KVS є системою Append-Only, він надає чіткі API ('kvs:delete') для виконання процедур очищення даних (наприклад, для забезпечення вимог GDPR "Право на забуття"). Під час видалення запису, бекенд RocksDB гарантовано помічає блоки як видалені (Tombstones), які під час подальшої компресії фізично стираються з носія без можливості відновлення (MP-6(8)). Параметр: tombstone_deletion_enabled Тип: boolean Значення: true
97	Використання носіїв інформації (марковані томи)		MP-7(1)	KVS може конфігуруватись на використання виключно заздалегідь визначених (іменованих) просторів таблиць на авторизованих томах зберігання, забороняючи використання невідомих чи немаркованих баз даних (MP-7(1)). Параметр: authorized_volumes_only Тип: boolean Значення: true
8. ПЛАНУВАННЯ БЕЗПЕРЕРВНОЇ РОБОТИ (CP)				
98	Резервне копіювання інформаційної системи		CP-9	Система здійснює автоматичне створення резервних копій бази даних KVS. Бекапи можуть зберігатися локально або відправлятися до хмарних сховищ, гарантуючи відновлення даних відповідно до RTO/RPO. Параметр: system_backup Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
99	Відновлення інформаційної системи		CP-10	KVS забезпечує механізми швидкого відновлення з резервних копій ('kvs:restore/1'), дозволяючи адміністраторам відновити працездатність вузла з гарантією логічної цілісності журналу транзакцій. Параметр: system_recovery Тип: boolean Значення: true
9. ФІЗИЧНИЙ ЗАХИСТ ТА ЗАХИСТ НАВКОЛИШНЬОГО СЕРЕДОВИЩА (PE)				
100	Фізичний доступ		PE-2	Регламентується інструкціями з режиму ЦОД (див. розділ PE у digital-profile.pdf). Параметр: physical_access_doc_ref Тип: string Значення: digital-profile.pdf
101	Контроль фізичного доступу		PE-3	Регламентується системами СКУД будівлі (див. розділ PE у digital-profile.pdf). Параметр: physical_access_control_ref Тип: string Значення: digital-profile.pdf
10. ОЦІНКА РИЗИКІВ (RA)				
102	Оцінка ризиків		RA-3	Всі ідентифіковані вразливості або загрози фіксуються в реєстрі 'itsm', де їм присвоюється рівень критичності. На базі цього рівня розраховується пріоритет та призначаються відповідальні особи. Параметр: risk_assessment Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
103	Сканування вразливостей	Використовувати заходи ПДТР за [Призначення: визначені організацією місця] [Вибір (один або кілька): [Призначення: з визначеною організацією частотою]; [Призначення: за визначеними організацією подіями або показниками]].	RA-5	Система передбачає можливість інтеграції зовнішніх сканерів вразливостей, звіти яких автоматично перетворюються на тикети усунення ризиків в системі 'itsm'. Параметр: vulnerability_scanning Тип: boolean Значення: true
11. ЗАХИСТ СИСТЕМ ТА КОМУНІКАЦІЙ (SC)				
104	Ізоляція функції безпеки	Розділяти функціональність користувача, включно зі службами, що призначені для користувача інтерфейсу, від функціональності системного управління.	SC-2	Функції безпеки (шифрування, авторизація) виконуються в ізольованих процесах Erlang VM, окремо від бізнес-логіки системи. Ця архітектура Actor Model унеможливорює втручання несанкціонованих процесів у роботу механізмів безпеки. Параметр: security_function_isolation Тип: boolean Значення: true
105	Інформація в загальних ресурсах системи	Запобігати несанкціонованій та ненавмисній передачі інформації через спільні системні ресурси.	SC-4	Erlang VM не використовує спільну пам'ять (shared memory) між процесами сесій N2O. Пам'ять звільняється автоматично (Garbage Collection) після обробки запиту, запобігаючи витоку залишкової інформації між різними користувачами. Параметр: shared_resource_protection Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
106	Захист від атак «відмова в обслуговуванні» (DoS)	а. [Призначення: захистити від; Обмежити] наслідки наступних типів подій відмови в обслуговуванні (DoS): [Призначення: визначені організацією типи подій відмови в обслуговуванні]; б. Застосувати наступні заходи захисту для досягнення мети відмови обслуговування [Призначення: заходи захисту визначені організацією, за типом події відмови в обслуговуванні].	SC-5	Інфраструктура N2O/Cowboy обробляє сотні тисяч конкурентних WebSocket-з'єднань завдяки легкості Erlang-процесів. Вбудовані механізми rate-limiting, обмеження розміру payload та таймаут захищають від атак на виснаження ресурсів (Slowloris, Flood). Параметр: dos_protection Тип: boolean Значення: true
107	Захист периметра (Boundary Protection)	а. Контролювати та управляти зв'язком на зовнішньому периметрі системи та на ключових внутрішніх периметрах всередині системи. б. Реалізувати підмережі для загальнодоступних компонентів системи, які є [Вибір: фізично; логічно] відділені від внутрішніх мереж організації. с. Підключатися до зовнішніх мереж або систем тільки через керовані інтерфейси, що складаються з пристроїв захисту периметру, і розташованих відповідно до архітектури безпеки та приватності організації.	SC-7	Всі зовнішні підключення приймаються виключно через єдиний порт (керований інтерфейс), що обробляється веб-сервером (Cowboy). Доступ до внутрішніх API і вузлів кластера блокується правилами мережевого екранування за замовчуванням (Default Deny). Параметр: boundary_protection Тип: boolean Значення: true
108	Захист цілісності та конфіденційності під час передачі	Забезпечити [Вибір (один або кілька): конфіденційність; цілісність] інформації, що передається.	SC-8	Передача інформації між клієнтом і сервером здійснюється виключно через зашифровані канали (WSS/TLS), що унеможливорює перехоплення (Man-in-the-Middle) або несанкціоновану модифікацію даних на льоту. Параметр: transmission_confidentiality Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
109	Розрив мережевого з'єднання	Завершити з'єднання з мережею, яке пов'язане із сеансом зв'язку в кінці сеансу або після [Призначення: визначений організацією період часу] бездіяльності.	SC-10	Протокол N2O автоматично розриває мережеве з'єднання після завершення комунікаційного сеансу або перевищення часу очікування (Inactivity Timeout), звільняючи ресурси та сесію. Параметр: network_disconnect_timeout Тип: integer Значення: 3600
110	Криптографічне управління ключами	Встановити та управляти криптографічними ключами для криптографічних засобів, які використовуються в системі відповідно до [Призначення: визначені організацією вимоги до генерації, поширення, зберігання, доступу та знищення ключів].	SC-12	Керування ключами та сертифікатами для встановлення захищених з'єднань делегується бібліотеці 'synrc/ca' та інтегрованим механізмам TLS OC, що відповідають чинним криптографічним стандартам. Параметр: cryptographic_key_management Тип: boolean Значення: true
111	Криптографічний захист	а. Визначити [Призначення: використання криптографічних засобів, визначених організацією]; б. Впровадити [Завдання: визначені організацією види криптографії для кожного визначеного криптографічного використання].	SC-13	Система підтримує використання схвалених криптографічних алгоритмів (AES-GCM, SHA-256/512, ДСТУ 4145-2002 через відповідні модулі), які забезпечують необхідний рівень стійкості. Параметр: cryptographic_protection Тип: boolean Значення: true
112	Автентичність сеансу зв'язку	Забезпечити автентифікацію сеансів зв'язку.	SC-23	Автентичність WebSocket-сесій N2O захищається токенами з криптографічним підписом (HMAC). Це гарантує, що повідомлення в рамках сесії не можуть бути підроблені або інжектвані сторонньою особою. Параметр: session_authenticity Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
12. ЦІЛІСНІСТЬ СИСТЕМИ ТА ІНФОРМАЦІЇ (SI)				
113	ПЕРЕВІРКА ВВОДУ ІНФОРМАЦІЇ	Перевіряти дійсність [Призначення: визначена організацією введена інформація].	SI-10	Система повинна перевіряти вхідну інформацію перед тим, як її обробляти та зберігати, щоб захиститись від ін'єкцій та забезпечити логічну цілісність. Екосистема Synrc (Nitro, Form) використовує архітектуру Server-Side Rendering (через N2O WebSockets) та декларативну серверну валідацію, що усуває цілі класи вразливостей.
114	Перевірка вводу перевизначення (лише серверна валідація)		SI-10(1)	Клієнтська сторона (браузер) в 'synrc/nitro' не містить логіки валідації, яку можна було б обійти чи перевизначити (override) через маніпуляції з DOM або JS. Уся перевірка жорстко зашита у виконуваний код Erlang ('synrc/form'). Жодне клієнтське перевизначення не здатне змінити правила серверної валідації. Параметр: server_side_validation_only Тип: boolean Значення: true
115	Перевірка вводу інформації помилок (екранування HTML)		SI-10(2)	Повідомлення про помилки валідації генеруються на сервері (Erlang) і передаються клієнту через WebSocket як готові безпечні HTML-фрагменти (екрановані 'nitro'), запобігаючи виникненню XSS під час відображення помилкового вводу користувачу. Параметр: escape_html_output Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
116	Передбачувана поведінка (декларативні Records)		SI-10(3)	Оскільки валідація описана декларативно (Record-структурами з типами полів, як-от 'integer', 'string', 'date'), реакція системи на некоректні дані завжди є 100% передбачуваною (Predictable Behavior). Відсутні приховані клієнтські скрипти, що можуть реагувати непередбачувано на специфічний ввід. Параметр: predictable_behavior Тип: boolean Значення: true
117	Часові взаємодії (таймаути N2O)		SI-10(4)	Оскільки ввід передається через сталий WebSocket-зв'язок (N2O), система має вбудований контроль тайм-аутів з'єднання та захист від перевантажень (Rate-limiting). Довгі запити або неповний ввід просто ігноруються після завершення вікна сесії, блокуючи атаки типу Slowloris. Параметр: timing_interactions Тип: boolean Значення: true
118	Обмеження вводу довіреними джерелами і форматами		SI-10(5)	Бібліотека 'form' пропускає дані лише для тих полів, які явно задекларовані в схемі форми (Approved Formats). Pattern Matching платформи Erlang автоматично відкидає будь-які JSON/BERT payload-пакети, які містять незадекларовані поля (унеможлижуючи Mass Assignment Vulnerability) або походять з неавторизованого джерела (Trust Zone). Параметр: strict_type_checking Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
119	Профілактика вводу даних (блокування через АВАС)		SI-10(6)	Комбінація 'nitro' та 'abac' дозволяє здійснювати профілактику (Prevention): якщо користувач не має права вносити дані в певне поле, це поле взагалі не рендериться на стороні клієнта або рендериться в стані 'readonly/disabled', а бекенд-валідатор автоматично блокує будь-яку спробу його програмно передати (Data Input Prevention at source). Параметр: data_input_prevention Тип: boolean Значення: true
13. РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR)				
120	Політика та процедури реагування на інциденти		IR-1	Політика реагування на інциденти закріплена безпосередньо у бізнес-процесах (BPMN) 'erpuno/itsm', забезпечуючи неухильне виконання процедур на кожному кроці життєвого циклу інциденту. Параметр: incident_policy_enforcement Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
14. ПЛАНУВАННЯ (PL)				
121	План безпеки системи	а. Розробити план захисту інформації та персональних даних для інформаційної системи, який: 1. узгоджується з архітектурою підприємства організації; 2. чітко визначає складові компоненти системи; 3. описує оперативний контекст інформаційної системи з точки зору завдань та процесів; 4. визначає осіб, які виконують системні ролі та обов'язки; 5. визначає тип інформації, яка обробляється, зберігається та передається системою; 6. надає огляд вимог безпеки та приватності інформаційної системи; 7. описує будь які конкретні загрози системи, які викликають стурбованість організації; 8. надає результати оцінки ризику конфіденційності для систем, в яких обробляються персональні дані; 9. описує робоче середовище інформаційної системи та будь які залежності від систем або компонентів систем або підключень до таких систем та їх компонентів; 10. надає огляд вимог безпеки та конфіденційності системи; 11. визначає будь які відповідні контрольні базові рівні або накладання, якщо вони застосовуються; 12. описує чинні або заплановані заходи щодо забезпечення безпеки та приватності, включно з обґрунтуванням рішень щодо налаштування 13. включає виявлення ризиків для архітектури безпеки і приватності, а також проектних рішень; 14. включає дії, пов'язані з безпекою та конфіденційністю, які впливають на систему, виконання яких вимагає планування та координацію з [Призначення: визначені організацією окремі особи або групи]; 15. розглядається та затверджується уповноваженою посадовою особою або призначеним представником до початку реалізації плану. б. Поширити копії планів захисту інформації та персональних даних і повідомляти про подальші зміни планів серед [Призначення:визначеного організацією персоналу або ролей]. с. Переглядати плани захисту інформації та персональних даних [Призначення: з визначеною організацією частотою]. д. Оновлювати плани захисту інформації та персональних даних для врахування змін в інформаційній системі й робочому середовищі або проблем, виявлених у ході реалізації або оцінювання заходів безпеки та приватності. е. забезпечити захист планів захисту інформації та персональних даних від несанкціонованого розголошення та змін.	PL-2	Система підтримує автоматичну генерацію актуального Плану безпеки системи на основі цього профілю (СМ). План чітко визначає всі технічні та організаційні контролі (АС, АУ, SC, СМ тощо), середовище функціонування та архітектуру. Параметр: system_security_plan Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
122	Правила поведінки	а. Створити та надати особам, що потребують доступу до інформаційної системи, правила, які описують їхні обов'язки й очікувану поведінку щодо інформації та використання інформаційної системи, безпеки та приватності. б. Отримати документальне підтвердження від таких осіб про те, що вони прочитали, зрозуміли та погодилися дотримуватися правил поведінки, перш ніж дозволяти доступ до інформації та інформаційної системи. с. Переглядати й оновлювати правила поведінки [Призначення: з визначеною організацією частотою]. д. Вимагати від осіб, які підписали попередню версію правил поведінки, перечитати та повторно підписати правила [Вибір (один або декілька): [Призначення: з визначеною організацією частотою]; коли правила переглядаються чи оновлюються].	PL-4	Для всіх користувачів платформи (організаційних та зовнішніх) визначаються правила поведінки. Згода з правилами (наприклад, Terms of Service, NDA) фіксується в базі даних KVS під час онбордингу, перед наданням доступу до ERP/1. Параметр: rules_of_behavior Тип: boolean Значення: true
123	Архітектура безпеки	а. б. Розробити архітектуру безпеки та приватності для інформаційної системи, яка: 1. характеризує методологію, вимоги та підходи, які слід вживати для забезпечення конфіденційності, цілісності та доступності інформації, що циркулює в системі; 2. характеризує методологію, вимоги та підхід до обробки персональних даних для мінімізації ризику їх втрати; 3. характеризує, як архітектури безпеки та приватності інтегруються в архітектуру підприємства; 4. характеризує будь-які припущення, що пов'язані з безпекою та приватністю, щодо зовнішніх служб і залежності від них. Переглядати й оновлювати архітектуру безпеки та приватності [Призначення: з визначеною організацією частотою], щоб відображати оновлення в архітектурі підприємства. с. Відображати заплановані зміни архітектури плану безпеки та приватності, концепції експлуатації інформаційної системи, аналізу критичності, організаційних заходах, постачань та закупівель.	PL-8	Архітектура безпеки платформи (Actor Model, ізоляція процесів, Zero Dependencies, Append-Only логуювання) розробляється інтегровано з загальною архітектурою підприємства. Вона регулярно переглядається на відповідність державним стандартам (НД ТЗІ, NIST SP 800-53). Параметр: security_architecture Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
15. УПРАВЛІННЯ РИЗИКАМИ В ЛАНЦЮГУ ПОСТАЧАННЯ (SR)				
124	План управління ризиками ланцюга постачання	а. Розробіть план управління ризиками ланцюга постачання, пов'язаними з дослідженнями та розробкою, проектуванням, виробництвом, придбанням, доставкою, інтеграцією, експлуатацією та обслуговуванням, а також утилізацією таких систем, компонентів системи або послуг для системи: [Призначення: системи, визначені організацією, системні компоненти або системні служби]; б. Перегляньте та оновіть план управління ризиками ланцюга постачання [Призначення: частота, визначена організацією] або за потреби для усунення загроз; с. Захистіть план управління ризиками ланцюга постачання від несанкціонованого розголошення та модифікації.	SR-2	План управління базується на принципі відмови від стороннього коду. Замість інтеграції сотень неперевіраних бібліотек, команда розробляє всі необхідні компоненти (веб-сервер N2O, KVS, CA) самостійно в єдиному монорепозиторії. Параметр: zero_dependency_policy Тип: boolean Значення: true
125	Контроль та захист ланцюга постачання	а. Встановлення процесу або процесів для виявлення та усунення слабких місць або недоліків в елементах і процесах ланцюга постачання [Призначення: визначена організацією система або компонент системи] у координації з [Завдання: персонал ланцюга постачання, визначений організацією]; б. Використовуйте такі заходи захисту, щоб захистити систему, компонент системи або системну службу від ризиків ланцюга постачання та обмежити шкоду чи наслідки від подій, пов'язаних із ланцюгом постачання: [Призначення: заходи захисту ланцюга постачання, визначені організацією]; с. Задokumentуйте обрані та впроваджені процеси та заходи захисту ланцюгом постачання у [Вибір: плани безпеки та приватності; план управління ризиками ланцюга постачання; [Призначення: документ, визначений організацією]].	SR-3	Заборонено використання автоматичних менеджерів пакетів для завантаження коду під час збірки. Весь вихідний код системи та модулів міститься безпосередньо в репозиторії проекту, що гарантує 100% контроль над кожним рядком коду, який компілюється. Параметр: strict_code_vendoring Тип: boolean Значення: true
126	Аудит та огляди постачальників	Оцініть і перегляньте ризики ланцюга постачання, пов'язані з постачальниками або підрядниками, системою, системним компонентом або системою послугою, яку вони надають [Призначення: частота, визначена організацією].	SR-6	Єдиним зовнішнім «постачальником» є розробник платформи Erlang/OTP (компанія Ericsson та спільнота). Оновлення версій OTP проходять жорстку перевірку перед їх застосуванням на продуктивних серверах. Параметр: erlang_otp_supplier_review Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
127	Автентичність компонентів	а. Розробити та впровадити політику та процедури боротьби з підробками, які включають засоби для виявлення та запобігання потраплянню підроблених компонентів у систему; б. Повідомляти про підроблені системні компоненти [Вибір (один або кілька): джерело підробленого компонента; [Призначення: зовнішні звітні організації, визначені організацією]; [Призначення: персонал або ролі, визначені організацією]].	SR-11	Будь-які оновлення або патчі самої системи передаються виключно через захищені канали із застосуванням криптографічних підписів ('sync/ca'), що виключає можливість підміни бінарних файлів під час розгортання. Параметр: component_ authenticity Тип: boolean Значення: true